

Project ID :

25-26J-058

1. Topic (12 words max)

"SecureTrustOTA: A Resilient and Trust-Based OTA Framework for IoT Devices"

2. Research group the project belongs to

IAS - Information Assurance & Security

3. Specialization of the project belongs to

Cyber Security (CS)

4. If a continuation of a previous project:

Project ID	
Year	

5. Brief description of the research problem including references (200 – 500 words max) – references not included in word count.

The rapid growth of the Internet of Things (IoT) has resulted in billions of connected devices deployed across industries such as healthcare, agriculture, transportation, and smart homes. These devices often operate in remote or resource-constrained environments and require regular firmware updates to patch vulnerabilities, enhance functionality, and maintain security. However, Over-the-Air (OTA) firmware updates, though convenient, expose IoT systems to serious security risks including unauthorized firmware injection, rollback attacks, tampering, and device bricking.

Traditional OTA mechanisms often rely on a perimeter-based trust model and lack the resilience needed to ensure safe firmware delivery and installation. Additionally, many IoT devices have limited memory, processing power, and battery life, making heavyweight security protocols impractical. As such, there is a critical need for a lightweight, secure, and robust OTA framework that ensures firmware authenticity, integrity, and availability without compromising device performance.

SecureTrustOTA addresses this gap by introducing a multi-layered OTA security framework tailored for constrained IoT environments. It incorporates four core components: (1) lightweight encryption mechanisms for secure firmware transmission, (2) a Zero-Trust Authorization Model that enforces strict access and privilege control, (3) a Threshold-Based Anomaly Detection Engine that flags abnormal update behavior based on predefined limits, and (4) a resilient fail-safe engine to protect devices from bricking or unauthorized rollback.

This framework ensures that only verified and authorized updates are accepted, prevents downgrade attacks, detects suspicious activity through rule-based anomaly checks, and allows safe recovery in case of update failures. Unlike conventional models, SecureTrustOTA does not rely on implicit trust; instead, every update transaction is authenticated, monitored, and controlled. By integrating lightweight cryptography, strict access enforcement, and adaptive anomaly response, the system maintains a low resource footprint while significantly improving update security.

This research specifically targets smart energy monitoring systems—such as solar power production sites and energy-intensive companies—where secure, reliable, and continuous firmware updates are critical to operational efficiency and safety.

References:

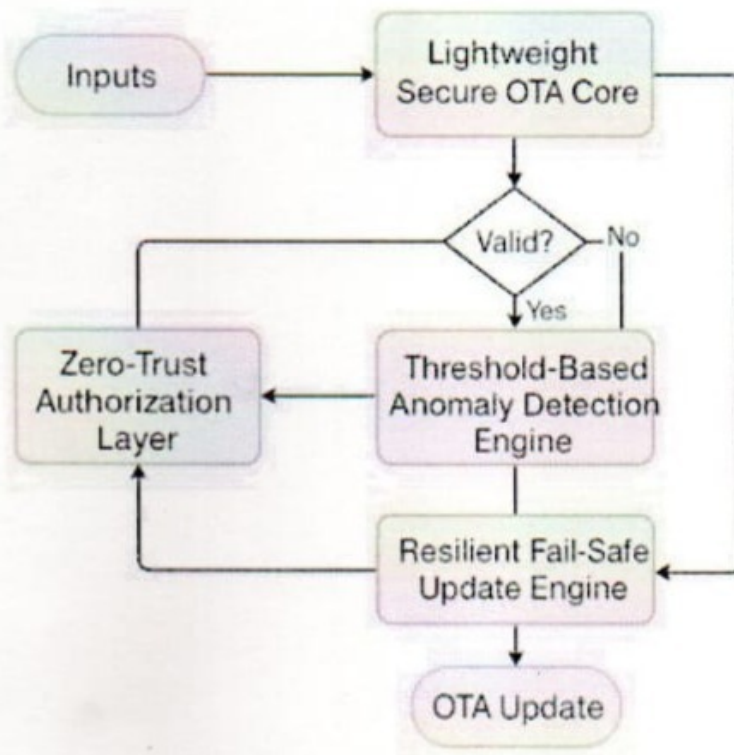
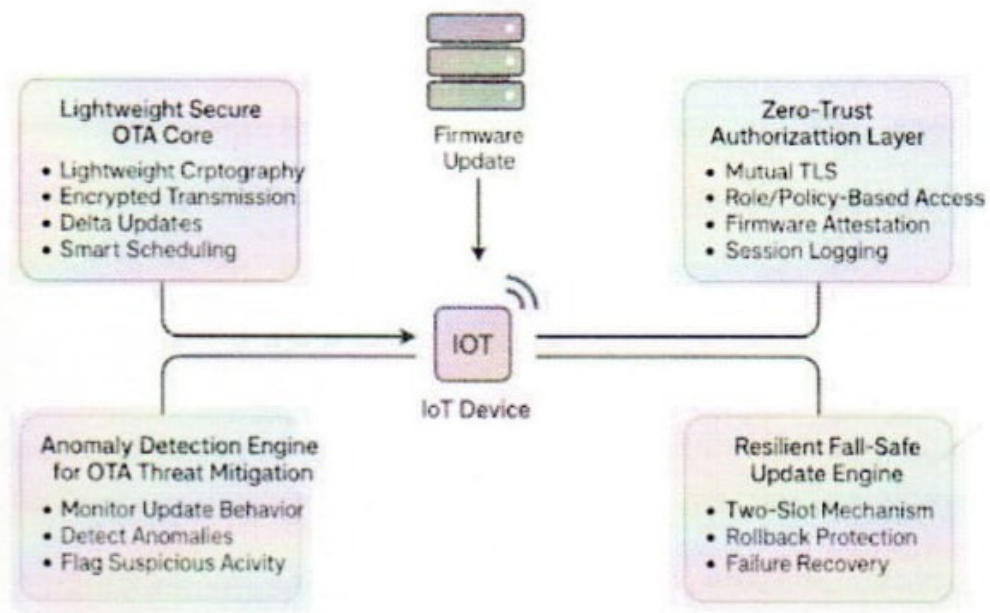
- [1] Mosenia, Arsalan, and Niraj K. Jha. "A comprehensive study of security of internet-of-things." *IEEE Transactions on emerging topics in computing* 5.4 (2016): 586-602.
- [2] Rose, Karen, Scott Eldridge, and Lyman Chapin. "The internet of things: An overview." *The internet society (ISOC)* 80.15 (2015): 1-53.
- [3] Stafford, V. "Zero trust architecture." *NIST special publication* 800.207 (2020): 800-207..
- [5] Falas, Solon, Charalambos Konstantinou, and Maria K. Michael. "A modular end-to-end framework for secure firmware updates on embedded systems." *ACM Journal on Emerging Technologies in Computing Systems (JETC)* 18.1 (2021): 1-19.
- [6] Asokan, N., et al. "ASSURED: Architecture for secure software update of realistic embedded devices." *IEEE Transactions on Computer-Aided Design of Integrated Circuits and Systems* 37.11 (2018): 2290-2300.
- [7] Feng, Xiaotao, et al. "Detecting vulnerability on IoT device firmware: A survey." *IEEE/CAA Journal of Automatica Sinica* 10.1 (2022): 25-41.
- [8] Chatterjee, Ayan, and Bestoun S. Ahmed. "IoT anomaly detection methods and applications: A survey." *Internet of Things* 19 (2022): 100568.

6. Brief description of the nature of the solution including a conceptual diagram (250 words max)

SecureTrustOTA is a layered security framework designed to deliver authenticated, authorized, and tamper-proof Over-the-Air (OTA) firmware updates to resource-constrained IoT devices. It integrates four key components to ensure end-to-end protection, even in low-power or unreliable environments.

1. **Lightweight Secure OTA Core** – Uses efficient cryptographic algorithms like ECC and AES-CCM to encrypt firmware updates while keeping CPU, memory, and power usage low. Delta update mechanisms reduce the size of transmitted data, saving bandwidth and time.
2. **Zero-Trust Authorization Layer** – Enforces strict identity verification and access control using mutual TLS (mTLS) and policy-based permissions. Firmware attestation mechanisms verify the legitimacy of the update before installation. Logging and auditing provide traceability.
3. **Threshold-Based Anomaly Detection Engine** – monitors OTA update behavior by checking parameters like update size, duration, and memory usage against predefined limits. If any value exceeds the safe threshold, it flags the update as suspicious. This lightweight, non-ML approach is ideal for detecting abnormal activity in resource constrained IoT devices.
4. **Resilient Fail-Safe Update Engine** – Incorporates a dual-slot system where the device retains the previous firmware version and can revert to it if the update fails. It includes rollback protection, secure logging, and failure recovery features.

Together, these modules form a secure, scalable, and resilient OTA update pipeline. The solution is highly modular and can be adapted to various IoT platforms and environments without requiring high computational resources.



7. Brief description of specialized domain expertise, knowledge, and data requirements
(300 words max)

1. Domain Expertise

This project spans several specialized domains. Expertise in IoT system design is essential to understand the constraints and deployment scenarios of embedded devices. Cybersecurity knowledge is crucial to ensure secure firmware handling, integrity checks, and robust authorization models. Familiarity with network security and over-the-air (OTA) protocols is also required to implement secure transmission methods and validate data exchanges. Additionally, a strong grasp of embedded software reliability is necessary for designing a fail-safe update mechanism that guarantees system resilience during firmware failures or tampering attempts.

2. Knowledge Requirements

Each module demands specific technical understanding:

The **Lightweight OTA Core** requires knowledge in **embedded cryptography**, including efficient algorithms like AES-CCM and ECC suited for constrained environments.

The **Zero-Trust Authorization Layer** involves applying **TLS/mTLS protocols**, **policy-based access control**, and cryptographic identity validation.

The **Threshold-Based Anomaly Detection Engine** requires understanding of **device behavior profiling**, **threshold tuning**, and rule-based decision systems for detecting abnormal update activity.

The **Resilient Fail-Safe Engine** demands skills in **system recovery design**, rollback protection, and secure update scheduling with minimal operational disruption.

3. Data Requirements

Each module relies on accurate operational and contextual data:

- 1.The OTA core depends on firmware metadata (version, size, hash).
- 2.The authorization layer uses device identity, certificates, and access policies.
- 3.The anomaly detection engine needs real-time metrics like update time, memory usage, and sensor conditions to evaluate anomalies.
- 4.The fail-safe engine uses system status logs, version counters, and rollback triggers to ensure safe recovery.

All data is essential for decision-making and must be handled securely and efficiently to maintain integrity across the OTA process.

8. Objectives and Novelty

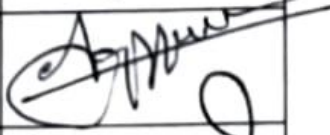
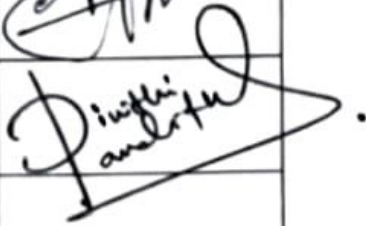
Main Objective To develop a secure, scalable, and resilient Over-the-Air (OTA) firmware update framework (SecureTrustOTA) for resource-constrained IoT devices by integrating lightweight encryption, Zero-Trust authorization, Threshold-Based Anomaly Detection Engine, and fail-safe update mechanisms.			
Member Name with Registration No	Sub Objective	Tasks	Novelty
Jayaweera N.S IT22362780	Establish a Zero-Trust authorization and policy enforcement system	- Implement mutual TLS (mTLS) - Design and enforce role-/policy-based access control - Integrate firmware attestation and audit logging - Authentication of devices - Update verification	Integrates Zero-Trust principles into OTA firmware delivery using mTLS and dynamic access policies
Mandira U.L.L.K IT22365996	Develop a lightweight and secure OTA delivery mechanism	- Implement ECC and AES-CCM encryption - Integrate delta update logic - Optimize transmission for low-power devices - Firmware validation - Secure transmission	Introduces a bandwidth-saving delta update model with lightweight encryption optimized for IoT constraints
Dilmith K.P.H.S IT21832130	Build a resilient, fail-safe update and rollback protection engine	- Design dual-slot update system - Implement rollback protection and recovery - Add secure logs and replay attack prevention	Provides a robust rollback-safe update system with secure time-based tamper detection.

		- Implement firmware performance monitoring to support rollback decisions - Integrate a scheduler to trigger updates during optimal, non-disruptive times.	
P A S N PERERA IT22307262	Implement a Threshold-Based Anomaly Detection Engine for OTA Threat Mitigation	- Define acceptable thresholds for key OTA parameters (e.g., update size, memory use, update time) - Monitor OTA behavior during and after firmware delivery - Detect and log threshold violations indicating suspicious activity - Trigger alerts or prevent updates when anomalies are detected - Evaluate system behavior under simulated attack or fault conditions - Validate and fine-tune threshold values using historical OTA update logs and simulated edge-case scenarios.	Introduces a lightweight, non-ML anomaly detection layer to OTA update systems. By enforcing rule-based thresholds on update patterns and device performance metrics, it adds proactive threat detection and firmware protection capabilities without requiring complex computation, ideal for constrained IoT environments

9. Individual component description of how it is complied with the specialization.

Member Name with Registration No	Description
Jayaweera N.S IT22362780	The Zero-Trust Authorization Layer is strongly aligned with Cybersecurity and Network Security specialization. It uses mutual TLS, access control, and firmware attestation, core security principles taught in secure communications and identity/access management. It demonstrates applied knowledge in zero-trust models and secure system design.
Mandira U.L.L.K IT22365996	The Lightweight Secure OTA Core aligns with the Embedded Security and Cryptography specialization. It involves implementing lightweight cryptographic techniques like ECC and AES-CCM suitable for constrained IoT environments. This directly applies secure software principles and optimization skills essential in embedded system development.
Dilmith K.P.H.S IT21832130	The Resilient Fail-Safe Update Engine matches the IoT Systems and Embedded Security domain. It involves designing recovery logic, rollback protection, and secure firmware versioning , critical for maintaining device stability and safety in real-world embedded IoT systems.
P.A.S.N.Perera IT22307262	This component aligns with the Cybersecurity and IoT Monitoring specializations. It uses threshold-based anomaly detection to monitor OTA update behavior, such as firmware size, update duration, and memory usage. If any parameter exceeds a defined safe limit, the system flags it as anomalous. This approach allows lightweight, real-time threat detection during firmware updates without relying on machine learning, making it ideal for resource-constrained devices. It enhances the OTA framework by adding proactive behavior checks to detect abnormal activity during update sessions.

10. Supervisor details

	Title	First Name	Last Name	Signature
Supervisor	Mr	Kavinga	Yapa	
Co-Supervisor	Ms	Dinithi	Pandithage	
External Supervisor				
Summary of external supervisor's (if any) experience and expertise				

a) Does the chosen research topic possess a comprehensive scope suitable for a final-year project?

Yes		No	
-----	--	----	--

Yes		No	
-----	--	----	--

Yes		No	
-----	--	----	--

Yes		No	
-----	--	----	--

Acceptable: Mark/Select as necessary

Topic Assessment Accepted	
Topic Assessment Accepted with minor changes*	
Topic Assessment to be Resubmitted with major changes*	
Topic Assessment Rejected. Topic must be changed	

* Detailed comments given below

Comments

--

Staff Member's Name	Signature

*Important:

1. According to the comments given by the evaluator, make the necessary modifications and get the approval by the **Evaluator**.
2. If the project topic is rejected, identify a new topic, and request the RP Team for a new topic assessment.